

Informe de Remediación de Seguridad

Sistema de Gestión de Correspondencia — **SISMAR**

PREPARADO POR	DIRIGIDO A	FECHA	REFERENCIA
AI SerNet — Equipo ASIA Arquitectura de Soluciones de IA	FOSCAL Equipo de Ciberseguridad	15 de julio de 2026	Auditoría SAST 14/07/2026 (20 hallazgos)

Resumen ejecutivo

El equipo ASIA de AISerNet recibió la auditoría de seguridad estática (SAST) practicada por FOSCAL sobre SISMAR, que identificó 20 hallazgos (4 críticos, 6 altos, 8 medios y 2 bajos). Verificamos cada punto contra el código fuente y ejecutamos un plan de remediación estructurado bajo la metodología STRATA v3 (test primero, verificación con evidencia y seguridad transversal). A la fecha de este informe, **19 de los 20 hallazgos están remediados y verificados**. El restante (SEC-016, gestor de paquetes) no constituye una vulnerabilidad sino una convención de herramienta; se responde como **excepción justificada** con aceptación de riesgo, sujeta a confirmación del cliente. El despliegue a pre-producción se mantuvo **bloqueado** durante toda la remediación.

19/20 REMEDIADOS	4/4 CRÍTICOS	6/6 ALTOS	40 TESTS EN VERDE	1 EXCEPCIÓN JUSTIF.
----------------------------	------------------------	---------------------	-----------------------------	-------------------------------

Estado por hallazgo

ID	SEV.	REMEDIACIÓN	ESTADO
SEC-001	CRÍTICA	.env fuera de control de versiones (rm --cached + .gitignore)	RESUELTO
SEC-002	CRÍTICA	Credenciales de prueba eliminadas del login + test de regresión	RESUELTO
SEC-003	CRÍTICA	Guard central de sesión/permisos en las 25 server actions	RESUELTO
SEC-004	CRÍTICA	GET /api/uploads exige JWT de sesión (401 sin sesión)	RESUELTO
SEC-005	ALTA	bcryptjs y cookie movidos a dependencies	RESUELTO
SEC-006	ALTA	Whitelist de tipo (PDF/PNG/JPG) y tamaño máx. 10 MB	RESUELTO
SEC-007	ALTA	Validación Zod (safeParse) integrada en las actions	RESUELTO
SEC-008	ALTA	Cookie httpOnly+secure+sameSite+path en set/refresh/clear	RESUELTO
SEC-009	ALTA	Rate limiting en login (5 intentos/min por usuario)	RESUELTO
SEC-010	ALTA	SVG bloqueado; tipos no whitelisted como attachment (anti-XSS)	RESUELTO
SEC-011	MEDIA	Content-Security-Policy añadido	RESUELTO
SEC-012	MEDIA	Strict-Transport-Security (HSTS) añadido	RESUELTO
SEC-013	MEDIA	Interfaz SessionPayload (elimina 'any' en auth)	RESUELTO
SEC-014	MEDIA	Bloques catch vacíos ahora registran con console.warn	RESUELTO
SEC-015	MEDIA	Logging limitado a error.message (sin stack traces)	RESUELTO
SEC-016	MEDIA	npm→pnpm: convención, no vulnerabilidad (npm es igual de seguro)	EXCEPCIÓN

ID	SEV.	REMEDIACIÓN	ESTADO
SEC-017	MEDIA	Lógica de upload unificada en src/lib/uploads.ts (DRY)	RESUELTO
SEC-018	MEDIA	createMany() elimina N+1 en recorridos y seed	RESUELTO
SEC-019	BAJA	Consecutivo con sufijo UUID (sin colisiones)	RESUELTO
SEC-020	BAJA	Contraseñas 8+ con complejidad (NIST)	RESUELTO

Detalle de las soluciones aplicadas

Se describe, para cada hallazgo, la solución implementada. Todas las correcciones cuentan con prueba automatizada y/o verificación funcional sobre el entorno de producción.

SEC-001 — Archivo .env con credenciales no excluido de Git

El archivo de entorno que contenía la cadena de conexión se retiró del control de versiones y se añadió a la lista de exclusión, junto con los archivos derivados. En los despliegues, los secretos se generan de forma aleatoria en el propio servidor y nunca se versionan. El valor presente en el repositorio era un marcador de posición de desarrollo, no una credencial real de ningún entorno.

SEC-002 — Credenciales de prueba expuestas en el login

Se eliminó por completo del código de la pantalla de inicio de sesión el bloque que mostraba usuarios y contraseñas de ejemplo. La eliminación es total —no un simple ocultamiento por entorno—, de modo que ese dato no existe en ninguna compilación. Se añadió una prueba que revisa todo el código y falla si esa contraseña vuelve a aparecer.

SEC-003 — Server actions sin autenticación ni autorización

Se creó un control central de autenticación y autorización que se ejecuta al inicio de cada operación del servidor. Las 25 acciones de negocio (correspondencia, catálogos, planillas y recorridos) exigen ahora una sesión válida y, donde corresponde, un permiso concreto del usuario. Una prueba automatizada impide que en el futuro se añada una acción sin esta protección.

SEC-004 — API de subida/entrega de archivos sin autenticación

El endpoint que entrega archivos valida ahora explícitamente la sesión (token de seguridad) antes de leer nada del disco. Si la petición no trae sesión o el token es inválido, responde con un error de autorización y no entrega el archivo. Esta protección debía ser explícita porque la seguridad general del sitio no cubre las rutas de tipo API.

SEC-005 — Dependencias de ejecución clasificadas como de desarrollo

Las librerías de cifrado de contraseñas y de manejo de cookies, necesarias en ejecución, se movieron a las dependencias de producción. Antes figuraban como de desarrollo, lo que habría provocado una caída de la aplicación al instalarla en modo producción. Los tipos de apoyo permanecen como dependencia de desarrollo, que es lo correcto.

SEC-006 — Subida de archivos sin validación de tipo ni tamaño

Se centralizó la subida de archivos en un único módulo con validación estricta: solo se aceptan PDF, PNG y JPG, se verifica que la extensión corresponda al tipo real y se limita el tamaño a 10 MB. Con ello se evita la carga de ejecutables maliciosos o de archivos muy grandes que puedan degradar el servicio.

SEC-007 — Esquemas de validación definidos pero sin usar

Los esquemas de validación que estaban definidos pero no se aplicaban se conectaron realmente a las operaciones del servidor. Ahora los datos de correspondencia y de administración se validan antes de procesarse, con mensajes de error homogéneos. Así se cierra la puerta a datos malformados o a inyecciones a través de los formularios.

SEC-008 — Cookie de sesión sin atributos seguros

La cookie de sesión se emite siempre con los atributos de seguridad correctos (httpOnly, secure, sameSite y path), unificados en una única definición reutilizada. Esta configuración se aplica de forma consistente al crear, refrescar y cerrar la sesión, eliminando las inconsistencias previas. Con ello la cookie no es accesible por scripts ni viaja en contextos inseguros.

SEC-009 — Sin límite de intentos en el inicio de sesión

Se incorporó un limitador que permite un máximo de cinco intentos de inicio de sesión por minuto y por usuario. Al superarlo, el sistema responde indicando el tiempo de espera, frenando los ataques de fuerza bruta. Para despliegues con múltiples instancias se prevé migrarlo a un almacén compartido.

SEC-010 — Archivos SVG servidos sin sanitización (XSS almacenado)

Se bloqueó por completo la subida de archivos SVG, que pueden contener scripts, y como defensa adicional cualquier tipo no permitido se entrega como descarga en lugar de mostrarse en el navegador. Se añadió la cabecera que impide interpretar tipos incorrectos. Así se elimina el riesgo de ejecución de código a través de archivos.

SEC-011 — Falta de política de seguridad de contenido (CSP)

Se añadió la política de seguridad de contenido, que restringe desde dónde puede cargar la aplicación scripts, estilos e imágenes. Es la defensa principal contra la inyección de código en el navegador. Se conservaron además todas las cabeceras de seguridad que ya existían.

SEC-012 — Falta de cabecera de transporte seguro (HSTS)

Se activó la cabecera HSTS, que obliga al navegador a comunicarse siempre por HTTPS durante dos años e incluye los subdominios. Con esto se impide que un atacante fuerce una degradación de la conexión a HTTP para interceptar el tráfico.

SEC-013 — Uso de tipos indefinidos en la autenticación

Se definió un tipo de datos explícito para el contenido de la sesión y se eliminó el uso de tipos indefinidos en las funciones de cifrado y descifrado. Esto recupera la verificación de tipos sobre información crítica y reduce el riesgo de errores al manipular la sesión.

SEC-014 — Bloques de captura de errores vacíos

Los bloques que capturaban errores sin hacer nada registran ahora una advertencia, sin interrumpir la operación del usuario. De este modo, un error en el análisis de datos —que podría indicar un intento de inyección— queda visible en los registros en lugar de silenciarse.

SEC-015 — Registro de errores con detalles internos

Se limitó el registro de errores en producción al mensaje esencial, evitando volcar el objeto completo o la traza interna. Con ello se impide la filtración de rutas del servidor y de detalles internos que podrían facilitar un ataque.

SEC-016 — Gestor de paquetes (npm en lugar de pnpm) — excepción justificada

El uso de npm en lugar de pnpm no constituye una vulnerabilidad, sino una convención de herramienta. npm ofrece el mismo nivel de seguridad y el archivo de bloqueo garantiza instalaciones reproducibles. Dado que el pipeline de despliegue ya está validado con npm, se solicita aceptar esta excepción; si el cliente lo requiere como norma, se ejecutará como cambio controlado independiente.

SEC-017 — Lógica de subida de archivos duplicada

La lógica de subida que estaba repetida en tres funciones se unificó en el módulo central. Con una sola implementación, cualquier corrección de seguridad se aplica de forma consistente en todos los puntos, eliminando el riesgo de corregir un sitio y olvidar los demás.

SEC-018 — Operaciones de base de datos en bucle (N+1)

Las inserciones que se ejecutaban una por una dentro de bucles se reemplazaron por operaciones por lote. Esto reduce de forma notable el número de consultas y mejora el rendimiento en la creación de recorridos y en la carga inicial de datos.

SEC-019 — Consecutivo basado solo en marca de tiempo

El consecutivo de la correspondencia, que podía colisionar por basarse únicamente en la marca de tiempo, combina ahora esa marca con un sufijo aleatorio. Se verificó con 500 generaciones simultáneas sin ninguna colisión, garantizando identificadores únicos.

SEC-020 — Contraseña mínima de solo seis caracteres

La política de contraseñas se reforzó a un mínimo de ocho caracteres con exigencia de mayúscula, minúscula y número, siguiendo la recomendación de NIST. Adicionalmente se entregó un script que sustituye las contraseñas iniciales por valores aleatorios fuertes, verificado contra la base de datos.

Verificación (Gate BDD)

- ✓ 40 pruebas automatizadas en verde (guards de autenticación, validación de archivos, esquemas Zod, atributos de cookie, rate limiting, cabeceras de seguridad y política de contraseñas).
- ✓ Compilación de producción sin errores (TypeScript estricto).
- ✓ Smoke E2E sobre el build de producción: inicio de sesión, registro de correspondencia con guards y validación activos, 401 en archivos sin sesión, cabeceras CSP/HSTS presentes y bloqueo del rate limiter al 6.º intento.
- ✓ Ningún despliegue a pre-producción durante la remediación.

Recomendación

AI SerNet considera SISMAR **apto para retomar el despliegue a pre-producción** una vez ejecutado el paso operativo de **rotación de las contraseñas de los usuarios iniciales** (que la auditoría señaló) y acordado el tratamiento de SEC-016. Quedamos atentos a la revisión del cliente para el cierre formal.